

The Architecture of safety

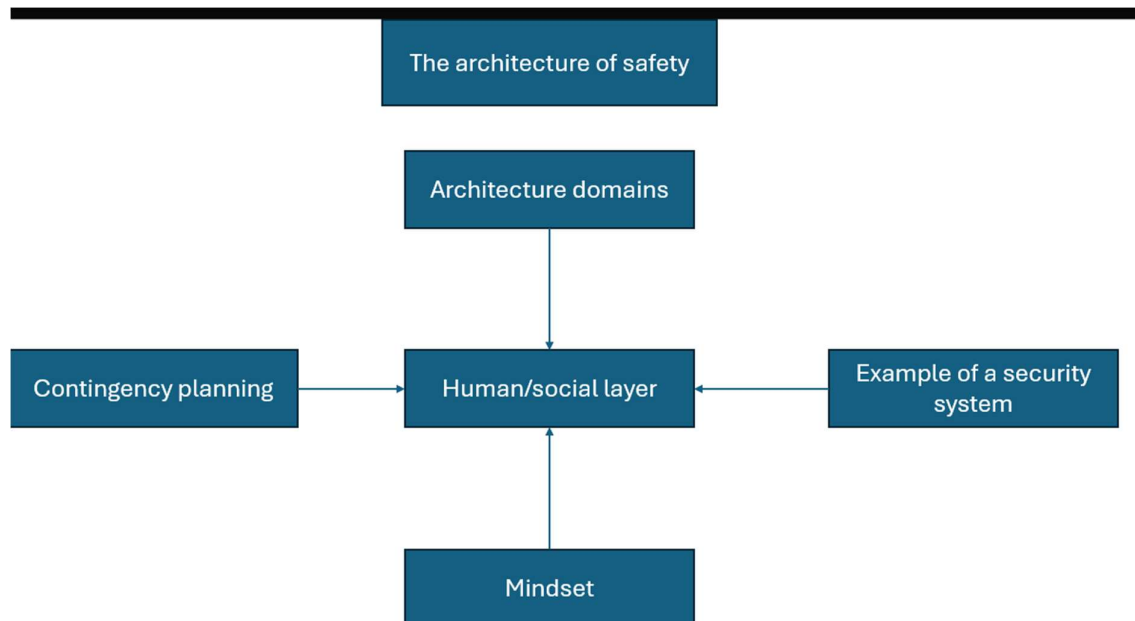
Contents

Introduction	2
Architecture mindset.....	3
Architecture Domains	4
Human and Social layer	5
Contingency planning and recovery	6
Personal security contingency planning and recovery.....	6
Organisation contingency planning and recovery.....	7
Example of a security system	8
Account security.....	8
Wi-Fi Security.....	9
Endpoint protection.....	10
Operational security	11
Threat modelling.....	12
Detection & Monitoring	13
Video links	14
Basic.....	14
Account security videos	14
Wi-Fi security videos.....	14
Endpoint protection videos	14
Operational security videos.....	15
Threat modelling videos	15
Detection & Monitoring	15
Advanced.....	16
Account security videos	16
Wi-Fi Security videos	16
Endpoint protection videos	16
Operational security videos.....	17
Threat modelling videos	17
Detection & Monitoring videos	17

Introduction

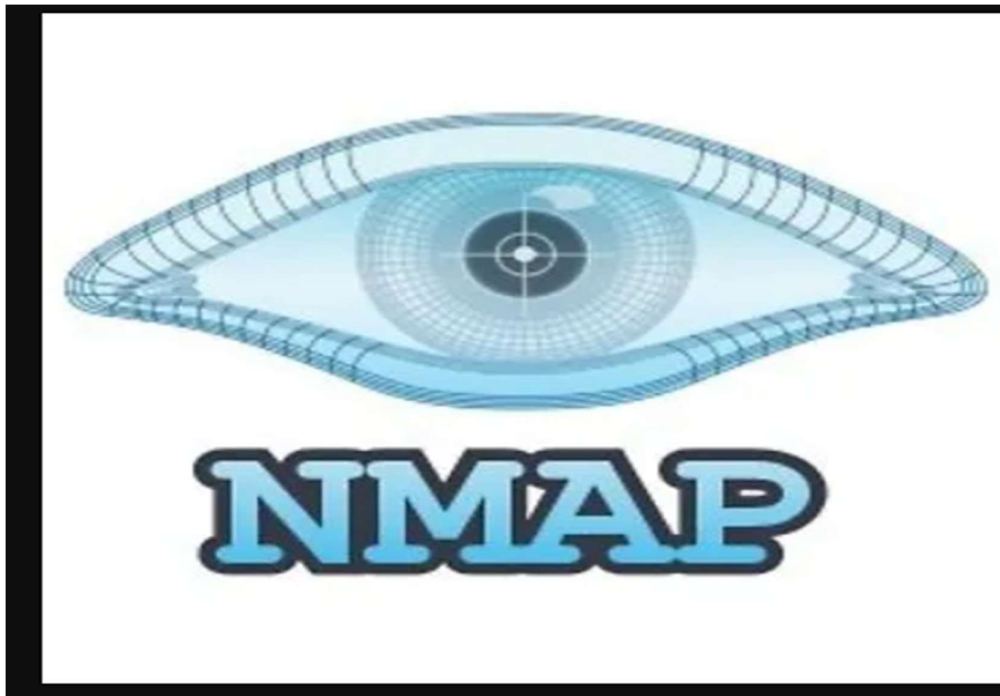
The architecture of safety is a security architecture that is built on the assumption that a system can always be breached. The architecture is built on multiple layers that are combined to protect a system from a variety of threats. This is what most technical experts would call defence in depth. This is because every time a new layer is added to a security system it raises the cost, resources and time needed to breach a system. This directly adapts security systems against an attacker's intent, which is to gain unauthorised access to a system without being detected. This architecture also suggests that a user should always plan for if a breach does happen. Contingency plans for breaches should be structured, realistic and easy to follow under stress.

While this architecture cannot provide a perfectly secured system, it can provide users with a real sense of safety and allow for organisations to comply with legal requirements like the GDPR and Data Protection Act. The core idea of this architecture is to provide a clear and structured framework for users to design their own security systems based on their own needs. This benefits a user because it allows them to design and adapt their security system based on their own resources and schedule. This architecture suggests that security is a continuous and evolving process. Security is not a one-time set-up. Do not blindly trust this architecture. Like any other system, this architecture can be wrong. Make sure to test it and adapt it to your own security needs.

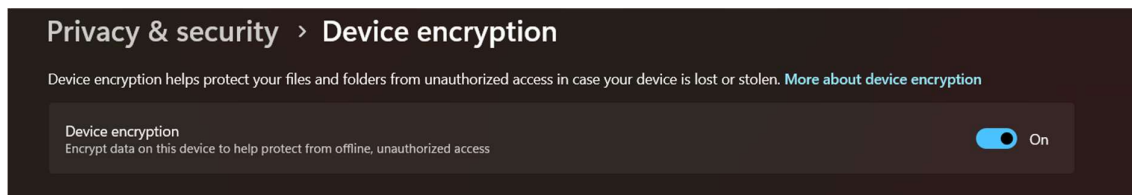


Architecture mindset

In terms of mindset, this architecture uses a balanced mindset of an attacker and a defender. An attacker's mindset can be used to discover vulnerabilities and to understand how an attacker would behave in a real-life attack. Whereas a defender's mindset can be used to design and set up defences to the user's needs or organisational guidelines. This allows for vulnerabilities to be found in a system before an attacker exploits it to gain unauthorised access. This architecture does not provide permission to test or discover vulnerabilities in systems you do not own; however, it does provide you with freedom to test your own security systems in the way that you choose.



The image above shows the network scanning tool Nmap. This is what an attacker may use to discover vulnerabilities, but I would advise against scanning systems that you do not own.



The image above shows device encryption. This is what a defender may use to protect their device from a physical threat such as device theft. Remember that security is about having multiple layers of security measures and protocols. Security is not a one-time setup.

Architecture Domains

The domains this architecture focuses on are account security, Wi-Fi-security, endpoint protection, operational security, threat modelling and detection & monitoring. While the 6 domains this architecture focuses on are the most important, an organisation may also prioritize and reinforce security on the domain of access control. This could include protections such as RBAC, session management and least-privilege policies.

- The first domain which is account security as you can probably understand from the name is preventing unauthorised access to your online accounts.
- This could be MFA or strong unique passwords.
- Account security also includes recovery codes. These are one time usage codes that allow you to recover access to your account if 2FA fails
- The second domain Wi-Fi security is protecting a home or organisation network from unauthorised access.
- Protections can include WPA3 and secure protocols such as SSH(Secure shell)
- Endpoint protection is protecting devices connected to a network. For example, a laptop or phone.
- Methods can include anti-virus software and encryption.
- Operational security is the practice of identifying, controlling and protecting critical information about yourself or organisation.
- This is because an attacker could use that insight to gain unauthorised access to a system.
- Actions can include limiting information posted on social media, but this can vary depending on your own security needs.
- Finally, threat modelling is identifying the type of attacker that is most likely to target you or your systems.
- Threat modelling allows you to design defences without making you paranoid or disrupting your daily life.
- Detection & monitoring is finding a threat before it can cause damage.
- Methods can include IPS/IDS systems, email-based login alerts and AI-driven anomaly detection.
- These 6 domains are the most important domains in cybersecurity, but they shouldn't be the only ones you consider.
- Make sure you always research and verify security methods before you implement them otherwise it may cause more trouble for you later.

Human and Social layer

The core layer of this architecture is the human and social layer. Most security systems nowadays, either try to control humans or kick them out of the system. Social threats such as phishing and weak operational security are the cause of 90% of breaches. The foundation of the security system should be the habits, discipline and environment used and maintained by the user. This architecture doesn't make humans the single point of failure instead it adapts the security system to work with humans instead of against them.

Machines and humans should support each other. This relationship should have clear boundaries and rules. Automation handles the heavy and processing load that security may require so that the user does not have to. Humans maintain the boundaries, habits and the big security decisions that may come. This provides humans with the power to have control over their own system without high cognitive load.

The most important part of the human layer is the way security decisions are handled. I would suggest three options for dealing with security decisions. The first option is to create a structure that will allow you to make a logical and safe security decision. This should be a structure that you can trust and follow under stress. A structure could be to identify consequences → Verify information → Make decision. The second option is not to make the security decision immediately especially if you are stressed, angry or sad. I would suggest taking some time to calm down. You can make the security decision once you are ready to do so. The third option is to call someone you trust to help you with the security decision. For organisations, this may be a CSIRT (Cyber security incident response team). For the average user, this may be a family member or a friend you trust. But remember the choice in most situations comes down to you. Choose the option that you believe is the most effective to your own security needs.

Contingency planning and recovery

This architecture's final layer is to be prepared for the worst-case scenarios and for recovery. This is because most systems today are built on the assumption that a breach will not occur. This architecture's final layer aims not to make the users or organisations paranoid but instead prepared and able to recover if a breach were to occur.

Personal security contingency planning and recovery

- Contingency plans for personal security should be structured, effective and easy to follow under stress
- They should also remain realistic and should be stored securely online in places that are accessible
- There should be one main contingency plan along with one alternative contingency plan, but this depends on security needs.
- The first step I would recommend is to take a deep breath and take a few minutes to calm down.
- This is because taking deep breaths helps keep you calm in stressful situations
- The second step I would recommend is to identify the situation.
- You should ask yourself questions like what was breached? How did it happen?
- The third step is to perform immediate containment of the breach
- This can include disconnecting a device from a network or running anti-virus scans
- The fourth step is to secure any data backups that have not been affected.
- This could mean securing encrypted backups on physical drives or cloud storage.
- The fifth step would be to research or note down options or actions that could be taken in the situation.
- I would recommend researching 3-4 options before deciding.
- The sixth step would be to attempt recovery of data or device
- This could mean using recovery mode, using a clean installation of Windows or restoring from a backup
- The seventh step I would recommend is to make improvements
- This could mean noting down the error, learning from it and making improvements based on what was learned

Organisation contingency planning and recovery

- Contingency plans for organisations should be focused on data recovery, reputation control and business operations.
- Contingency planning for organisations should be organised and easy to comply with during a real data breach.
- The first step would be to identify and contain the situation.
- This should be handled by the CSIRT
- This could mean disconnecting the device, changing passwords or removing malware from a device
- The second step would be to define clear roles and responsibilities for each team within the organisation
- This could mean social media team handle the narrative and public communication while the IT team works on recovery.
- CSIRT should handle any further security incidents
- The third step would be to launch an internal investigation into how the breach occurred
- This could mean reviewing security logs, questioning employees and working with law enforcement in some cases.
- The fourth step would be notifying the public of the current situation.
- This should be clearly explaining the situation, apologizing for any inconvenience caused.
- It should also explain what progress the company has made on the situation
- The fifth step is to attempt recovery of customer data.
- This could mean restoring from encrypted backups from physical drives or cloud storage.
- The final step should be to make sure the lesson has been learnt
- This could mean implementing stronger security protections and protocols like patch management, IDS/IPS detection systems or VLANs.
- The last step is dependent on what was found in the investigation

Example of a security system

An example of a security system that can be made using this architecture is simple but efficient. Let's say that the user has online accounts for TikTok, Instagram, Gmail and College. They have 3 devices a laptop with Windows 11 Home installed, iPad with the latest version of iPadOS and an iPhone 16.

Account security

- The user for their first layer could implement 16-character unique passwords for each account.
- These could be stored in a secure password manager such as Bitwarden or 1Password
- Bitwarden has a free tier, and it is open source
- They should also ensure that the password manager has a strong master password and MFA. MFA should be turned on.
- For the second layer, a user could use MFA. Which requires an attacker to bypass multiple security layers.
- The most secure and available option which is recommended by experts would be authentication apps.
- I would personally recommend Proton Authenticator or Microsoft Authenticator.
- There are other options such as email or SMS based MFA however these are weaker due to attack vectors such as SMS swapping.
- If a user wishes to protect their account further, they can implement hardware keys such as YubiKey or secure browsers such as Brave or Firefox as a third layer.
- The protections above such as hardware keys may be more complex to set up and may be expensive.



This is Proton Authenticator. This can be used for 2FA using OTP codes that change every 30 seconds. Remember to never share your codes with anyone. You can also use other options like Aegis or Microsoft Authenticator.

Wi-Fi Security

- A first layer the user could implement for their network is a WPA3 or WPA2
- WPA3 is the latest version of the Wi-Fi security protocol and should be turned on if possible.
- WPA3-personal should be used for the average user and small organisations.
- WPA3-enterprise can be used for large organisations
- If a router doesn't support WPA3 then WPA2-personal or WPA2-enterprise should be used.
- I would recommend never using WPA. It is outdated and highly unsecure
- A second layer the user could implement is strong passwords and secure protocols.
- I would recommend using a 24-character password with a mixture of numbers and letters for the network password
- A 5-word paraphrase is what I would recommend for a router's admin password
- Secure protocols such as TLS (Transport layer security), SSH (Secure Shell) and SFTP (Secure File Transfer Protocol)
- Protocols like FTPS (File transfer protocol secure) may be used for backward compatibility in older systems
- If a user or organisation wishes to protect a network further, features and methods such as VLANs, honeypots and custom firewall rules can be used. These can be more complex and difficult to set up

Endpoint protection

- A first layer the user could implement for their laptop is device encryption
- Device encryption is encrypting the system drive of the laptop or device to make it unreadable without authentication.
- On a Windows machine I would recommend device encryption for Windows 11 Home and BitLocker for Pro and Enterprise editions.
- If you need further protection, I suggest open-source software like VeraCrypt.
- A second layer would be implementing anti-malware software.
- Anti-malware otherwise known as anti-virus is used to protect devices from malware.
- I would recommend Windows Defender for those using Windows machines.
- There are alternatives such as Bitdefender Total Security
- The third layer could be implementing strong alphanumeric passcodes for devices like iPad, phones and laptops.
- I would suggest a minimum of 12 characters or using paraphrases with 4 random words that are easier to remember.
- If more advanced protection is required users or organisations may implement BIOS admin password, pre-boot authentication password and using encrypted separated backups.



The image above shows Windows Defender's real-time protection. This is absolute baseline protection for this domain. If you are not on Windows, you may use custom AV such as Bitdefender Total Security or Malwarebytes.

Operational security

- **A user may first scan and review the information displayed publicly on their social media accounts.**
- **This allows the user to directly control the information that others can see.**
- **I would recommend not allowing others to see personal information such as age, date of birth or address.**
- **A user may also not leave their device unattended or lock it when not in use**
- **This prevents an attacker with physical access from using the device without authentication.**
- **I would recommend turning screen timeout and having muscle memory for locking device when leaving it unattended or putting your laptop in hibernate mode.**
- **If a user or organisation wanted strict OPSEC, they may use Extreme compartmentalization, Air-Gapped & Dedicated and a zero-trust mindset.**
- **The methods and habits above are mostly used by journalists, intelligence agencies and high-risk organisations. It should only be used in high-level threat situations.**

Threat modelling

- A user or organisation may first identify what activities they do and data they store.
- This provides understanding of the importance of the data being protected and why an attacker may target the user
- I would recommend looking at your career or the data that your organisation may store about customers
- Second, a user would identify the most realistic threat model/actor. Which could be script kiddies, insider threats or cybercriminals.
- In this situation, the most realistic threat would be a script kiddie or insider threat from a friend or family member
- Finally, after identifying the most realistic threat model, the user would set up protections against attack vectors most used by that actor.
- These protections against a script kiddie could be strong passwords and MFA.
- Remember that protections are different against each threat actor.
- Threat models should be reviewed every 6 months for any changes or updates, but this isn't a set period for review.
- A high-risk user or organisation may face threat models such as cybercriminals, hacktivists and Nation-state/APT (Advanced Persistent Threat)
- A high-risk user may implement protections such as using virtual environments, air-gapped networks, burner phones and anonymous operating systems like Tails OS.
- Threat models for high-risk users should be reviewed every 1-2 months especially if facing a Nation-state threat model. This can be changed based on real-life events.

Detection & Monitoring

- The first layer a user could implement is login and security alerts.
- For an average user, this could be email-based login alerts
- For organisations, this could be system security alerts
- However, be warned that an attacker may use fake login alerts to steal credentials.
- The second layer that could be implemented is automatic updates for software
- This is focusing on keeping detection tools such as anti-virus software up to date and effective
- An average user may use operating system detection tools like Windows Defender or XProtect to detect malware.
- These detection tools use a mixture of behaviour and signature-based detection
- For organisations, Custom AVs such as Bitdefender Total Security may be used
- Bitdefender Total Security uses AI-driven anomaly detection, signature-based detection and behavioural patterns to find malware
- If a user or organisation wanted further detection and monitoring detection capabilities, they could implement IDS/IPS systems and next-gen firewalls



The image above shows results of a quick scan done by Windows Defender. This can be used to quickly detect and find malware on the device. However, for more sophisticated malware, scan options like full scan, custom scan and offline scan may need to be used.

Video links

These are video links you can use to help you understand the concepts stated in this architecture. These will be split between basic concepts and more advanced concepts. The choice of what level of detail you wish to dive into comes down to you. You do not have to watch all these videos to have security, they are simply to help with understanding. Remember that just like the architecture, these videos can be wrong. If you wish for extra verification, you can cross-reference these videos with other sources such as trusted security blogs.

Basic

Account security videos

1. <https://youtu.be/BsVkVa0n0T0> – Video comparing password managers
2. <https://youtu.be/IEHhivPJQ5w> – Video explaining MFA and the different MFA methods.

Wi-Fi security videos

1. <https://youtu.be/WZalfyvERcA> – Video explaining Wi-Fi security protocols (WPA2, WPA3 and more)
2. <https://youtu.be/6Ti23tE7UMI> – Video explaining basic security configuration on router. (Note: Router configuration may differ depending on the router you have)
3. <https://youtu.be/1zVZ9cWFnCc> – Video explaining basic network protocols (Note: This video does not fully cover secure protocols)
4. <https://youtu.be/P0Fk-K2eZF8> – Video explaining SSH (Secure shell)
5. <https://youtu.be/hExRDVZHhig> – Video explaining the network protocols SSL, HTTP, HTTPS and TLS. (Note: You can skip HTTP if you already understand it)

Endpoint protection videos

1. <https://youtu.be/msiJulFLoXM> – This is a video comparing the effectiveness of BitLocker and device encryption on Windows. (Note: This video may not be trustworthy, and extra verification may be needed by testing security provided by both solutions)
2. <https://youtu.be/xKrHWM1VeFQ> – This is a video comparing popular anti-virus solutions. (Note: Anti-virus solutions can be viewed differently by communities. It is important to ensure that you find the AV best suited to your own security needs.)
3. <https://youtu.be/jW626WMWNAE> – This is a video directly explaining how anti-virus software works.

Operational security videos

1. <https://youtu.be/rMSgnOYcEVE> – This video explains the fundamentals of OPSEC in 15 minutes (Note: Skip to 3:00 for actual content.)
2. https://youtu.be/dgd5_2pfEd0 – This video explains how to keep your identity private and provides security on social media.
3. <https://youtu.be/GXu5iGSbzbM> – This video explains OPSEC and habits

Threat modelling videos

1. <https://youtu.be/4oPDSjUEKIU> – This is a video explaining threat modelling frameworks. (Note: This is quite a professional video, and some parts of the video are not needed for personal security)
2. <https://youtu.be/rEnJYNkUde0> – This is a video on STRIDE Threat modelling. (Note: This was developed by Microsoft which makes it more trustworthy. However, this doesn't mean you should trust it blindly)

Detection & Monitoring

1. <https://youtu.be/MsGl6lX-YaI> – This is a video explaining incident detection and response in basic terms (Note: This is made by Google. It is also a cybersecurity course and it is over 1 hour long. Only watch what you need to)
2. <https://youtu.be/v3zuDJpRZ1U> – This is a video explaining how to manually download and install Windows updates (Note: While this is not directly important for detecting threats, it can help keep detection tools and devices up to date.)

Advanced

Account security videos

- <https://youtu.be/tbsNMtSHfwM> – This is a video explaining 2FA and how hardware security keys work such as YubiKey
- <https://youtu.be/UhANsAtvLN0> – This is a video that goes into a deeper level of detail into hardware security key while also explaining 2FA
- <https://youtu.be/F7-bW2y6lcl> – This video explains how Firefox works on different levels. (Note: This video was made 4 years ago, and Firefox's UI will have changed. Make sure to research and verify information through other trusted sources)

Wi-Fi Security videos

- <https://youtu.be/jC6MJTh9fRE> – This video explains the concept of VLAN and why they are used (Note: VLAN configuration can vary depending on the type of router used)
- <https://youtu.be/XdqP14NclZ0> – This video explains how VLAN work and how to configure one. (Note: You can skip to 7:34 for the demo. Remember that VLAN configuration differs with router configuration)

Endpoint protection videos

- <https://youtu.be/5rlZtasM-Pk> – Video explaining full disk encryption on Linux (Note: This only works for Linux-based operating system. Skip this video if you are using Windows or other operating systems)
- <https://youtu.be/zlYkol851dU> – This video explains what BIOS and UEFI are and the differences between them. (Note: This video is from 2015, and BIOS interfaces may be different.)
- Unfortunately, I was unable to find any clear videos explaining how to configure pre-boot authentication or BIOS master password. I would recommend looking at your device model's documentation to find out how to configure it.

Operational security videos

- <https://youtu.be/R7gWAKwHbhg> – This is a video explaining compartmentalization (Note: Skip to 1:59 for content. Compartmentalization may differ depending on your own resources. Make sure to always research and verify through other sources)
- I couldn't find any clear videos explaining how air-gapped networks work. To explain air-gapped systems in simple terms is a system that never connects to the internet. This could for example be a device like an external SSD. If you wish to find more information. This IBM article may provide you with more information. (Article link: <https://www.ibm.com/think/topics/air-gap>)
- <https://youtu.be/yn6CPQ9RioA> – This video explains how a zero-trust model works (Note: This video was made in 2021. While IBM can be trustworthy, you should never trust them or any other source fully)

Threat modelling videos

- <https://youtu.be/6xUH0t6ugIM> – This video explains different threat actors and attack vectors they may use. (Note: This may slightly use more technical terms due to the exam-focused approach. I would still recommend this for general use.)
- <https://youtu.be/mVKAyw0xqxw> – This video explains the Tails operating system in 1-2 minutes. (Note: This may be fast paced for non-technical users. Tails should only be used for high-risk users, but the choice comes down to you)
- https://youtu.be/mQP0wqNT_DI – This video explains how virtual machines work in 15 minutes. (Note: It was made 4 years ago, and virtual machine software may differ, but the key concepts should be the same)

Detection & Monitoring videos

- <https://youtu.be/l7FeR1MIRFY> – This is a video explaining IDS/IPS systems and comparing them to a firewall. (Note: This was made 3 years ago and systems may differ, but general concepts remain the same)
- <https://youtu.be/IWNfb4a1ay0> – This is a video explaining Next-gen-firewalls and traditional firewalls (Note: This was made 5 years ago, and next-gen firewalls may differ, but main concepts remain the same)